

LindfoSec VMDR Practice Lab

Configuration Profile Build & First Real Findings Review — LindfoSec-IT-Mgmt

This session covered two connected pieces of work: building a dedicated Cloud Agent Configuration Profile for all 4 AWS instances (replacing the default Initial Profile), and a full findings review on LindfoSec-IT-Mgmt, including one successfully remediated finding, one prioritization decision reasoned through independently, and one genuine “patch not yet available upstream” discovery.

1. Configuration Profile — LindfoSec-AWS-Profile

Built a dedicated profile scoped to all 4 AWS instances via the Location: HQ-Asturias-Spain tag, replacing the default Initial Profile they had carried since launch. The on-prem Windows workstation was deliberately left on a separate profile, keeping cloud and on-prem configuration independent.

Setting	Value chosen	Reasoning
Profile name	LindfoSec-AWS-Profile	Matches existing naming convention; distinct from the planned Windows-specific profile
Host assignment	Tag-based: Location: HQ-Asturias-Spain	Consistent with the tag-driven Asset Group design; scales automatically to future matching assets
Default profile for subscription	Unchecked	Prevents this AWS-specific profile from silently applying to future non-AWS agents
Suspend data collection	Unchecked	Confirmed this would stop scanning entirely — the opposite of intent
VM Scan Interval	240 minutes (platform default)	Fastest interval Qualys allows; on-demand CLI triggering covers faster feedback needs
Patch Management (PM)	Disabled	Not yet used elsewhere; auto-patching is a bigger capability to adopt deliberately, not as a side effect
Reduced Activity Period	None added	No real production hours to protect in a lab environment
Performance	Changed from Low to Normal	Informed by prior check-in troubleshooting; Low conserves resources at the cost of speed, unneeded here

Rollout verified on one instance before applying to the remaining three, following a test-then-scale approach. All 4 AWS instances confirmed showing the new profile post-rollout; the on-prem Workstation correctly remained on its own separate profile as intended.

2. LindfoSec-IT-Mgmt — Findings Overview

Metric	Value
Total confirmed vulnerabilities	27
Severity 5	5
Severity 4	10
Severity 3	11
Severity 2	1

3. Finding 1 — wget (QID 6035999)

Field	Value
Title	Ubuntu Security Notification for wget-related Vulnerabilities
Vendor Reference	USN-8543-1
CVEs	5 total: CVE-2026-58470, CVE-2024-38428, CVE-2026-58472, CVE-2026-58469, CVE-2026-58471
Severity	5 of 5
Remediation attempted	sudo apt update; sudo apt install wget — result: “wget is already the newest version”
Verification	Fresh apt update confirmed against all 4 Ubuntu repositories; apt list --upgradable listed 14 unrelated packages, wget not among them
Status	Remediation attempted — patch not yet available in Ubuntu's published repositories at time of check

4. Finding 2 — OpenSSH (QID 6035987)

Field	Value
Title	Ubuntu Security Notification for OpenSSH Vulnerabilities (USN-8533-1)
CVEs	8 total, primary: CVE-2026-60000
CVSSv3.1 Base / Temporal	9.4 / 8.2
Access Vector	ADJACENT_NETWORK — not exploitable from the open internet
Packages affected	openssh-client, openssh-server, openssh-sftp-server
Remediation attempted	sudo apt install openssh-server openssh-client — result: both reported already newest version
Status	Remediation attempted — patch not yet available upstream

5. Prioritization reasoning

Given the OpenSSH finding's CVSSv3.1 score of 9.4 and its Access Vector of ADJACENT_NETWORK, how should it be prioritized relative to a similar-severity finding on a public-facing asset?

The OpenSSH finding was assessed as lower priority than a comparable finding on the public-facing Sales & Marketing asset: although the CVSS severity is high, real-world exploitability is limited by its network position (not internet-facing), whereas an internet-facing asset carries materially higher real risk and potential business impact for the same severity level.

This reasoning reconstructs the core logic behind Qualys TruRisk (severity + exploitability + exposure = real priority) using raw CVSS, Access Vector, and Exploitability data directly.

6. Follow-up

- Check the USN-8487-1 and USN-8533-1 advisory pages directly to confirm whether Ubuntu has since published the patched builds for wget and OpenSSH, and re-attempt remediation once available.
- Build the separate Windows Configuration Profile for LindfoSec-RnD-Workstation, following the same deliberate-settings approach used for the AWS profile.
- Apply the same findings-review process to the remaining AWS instances to build a complete picture of the environment's real risk posture.
- Track “pending vendor patch” status accurately for wget and OpenSSH — distinct from both Fixed and unaddressed, and a more complete representation of the remediation lifecycle.